

The Personal Information Protection Law of the People's Republic of China (Chinese: 中华人民共和国个人信息保护法; pinyin: Zhōnghuá rénmin gònghéguó gèrén xìnxī bǎohù fǎ) referred to as the Personal Information Protection Law or ("PIPL") protecting personal information rights and interests, standardize personal information handling activities, and promote the rational use of personal information. It also addresses the transfer of personal data outside China.

The PIPL was adopted on August 20, 2021, and is effective November 1, 2021. It is related to, and builds on top of both China's Cybersecurity Law ("CSL") and China's Data Security Law ("DSL").

A reference English version was published on December 29, 2021.

History

On August 20, 2021, the Standing Committee of the 13th National People's Congress passed the Private Information Protection Law or ("PIPL"). The law, which took effect on November 1, 2021, applies to the activities of handling the personal information of natural persons within the borders of the China.

In comparison to countries in the West, China has developed its privacy laws over time at a slower pace. In recent years, though, China has more actively developed regulations, as the nation is considered a "global cyberforce." China's policies differ from Western nations, in that their perception of privacy is different due to historical and cultural reasons.

During the drafting process, the European Union's General Data Protection Regulation ("GDPR") was used as a model and in some areas, PIPL closely tracks the GDPR.

Provisions

Scope

The PIPL generally covers all organizations operating in China processing personal

information.

Long-arm jurisdiction

Some provisions also include long-arm jurisdiction over data collection and processes of organizations outside China. These apply when:

The purpose is to provide products or services to natural persons inside the borders;

Analyzing or assessing activities of natural persons inside the borders;

Other circumstances provided in laws or administrative regulations.

This presumably applies to offshore or multi-national companies with Chinese customers in China, for example Amazon who might be shipping goods to a Chinese buyer, or Apple who may have Chinese users in the American App Store.

All such entities are required to establish a dedicated entity or appoint a representative within China.

Exemptions

There are few exemptions, but one that was added during late drafting provides a non-consent legal basis for handling employee data, though employee consent is still needed for overseas transfer, such as to a global corporate parent.

Key themes

Individual privacy, control and consent are consistent themes throughout the law, which lays down key principles including:

Personal Information – Defining personal information, including sensitive information;

Legal Basis – All data collection must have a legal basis for collection. There are several bases,

but unlike in the GDPR, there is no legitimate interests basis;

Consent – A key legal basis is consent, which, unlike in the GDPR, must be obtained for each type of data processing activity, especially for transferring an individual's data overseas. Consent must also be "informed" with various types of notification and required content specified in the law;

Sensitive Data – Some types of personal information is sensitive, and the law provides an open-ended list of examples (unlike the GDPR's specific list of "special categories"), including biometrics, religion, specially designated status, medical health, financial accounts, and location tracking;

Protecting Children – All personal information of minors under the age of 14 is sensitive, and specific consent is required from parents to process this information. This is much stricter than in the GDPR;

Individual Rights – The PIPL gives individuals several key rights over their information, such as the right to correct, delete, and view or transfer the data collected about them.

Responsibilities – Several articles lay out the various responsibilities of various parties collecting, transferring, and handling personal information;

Government Use of Personal Information – The PIPL includes when and how government agencies can collect and process data on individuals, including for national security, emergency, and other purposes;

Overseas Transfers – Specific restrictions on transfer of personal data outside China;

Enforcement – Severe penalties for violations.

Definitions

The law defines the following:

Personal Information – Any type of information that identifies or can identify natural persons

recorded electronically or by other means, but does not include anonymized information.

Sensitive Personal Information – Personal information that once leaked or illegally used can easily cause natural persons to suffer encroachments on their dignity or harms to their persons or property; including information such as biometrics (including facial recognition), religious faith, particular identities, medical care and health, financial status, and location tracking, as well as the personal information of minors under the age of 14.

Individuals – People whose data is being collected for processed (similar to the GDPR's Data Subject).

Personal Information Handlers: – Organizations or individuals that independently make decisions about the purposes and methods of personal information handling in personal information handling activities.

Entrusted Persons – External entities who Information Handlers entrust to handle personal information, essentially third parties.

Large Processors – Companies that process large amounts of data, as defined in Article 40, including Critical Information Infrastructure Operators ("CIIO") from the China's Critical Infrastructure Regulations.

Handling of Personal Information: Personal information handling includes personal information collection, storage, use, processing, transmission, provision, disclosure, deletion, etc.

Automated Decision-Making: The use of computer programs to automatically analyse, evaluate, and make decisions on personal information on personal behavior habits, hobbies or economic, health, credit status, and so forth.

De-Identification: The process of handling personal information to make it impossible to identify a specific natural person without the help of additional information.

Anonymization: The process in which personal information is handled so that it cannot be

used to identify a specific natural person and cannot be restored after being so handled.

Legal basis

All personal information collection and processing must have one of the following legal bases:

Individuals' consent obtained;

Where necessary to conclude or fulfill a contract in which the individual is an interested party, or where necessary to conduct human resources management according to lawfully formulated labor rules and structures and lawfully concluded collective contracts;

Where necessary to fulfill statutory duties and responsibilities or statutory obligations;

Where necessary to respond to sudden public health incidents or protect natural persons' lives and health, or the security of their property, under emergency conditions;

Handling personal information within a reasonable scope to implement news reporting, public opinion supervision, and other such activities for the public interest;

When handling personal information disclosed by persons themselves or otherwise already lawfully disclosed, within a reasonable scope in accordance with the provisions of this Law.

Other circumstances provided in laws and administrative regulations.

Unlike in the GDPR, there is no legitimate interests basis. Therefore, most consumers will likely be covered by giving their direct consent (such as for cookies, newsletters, etc.) or by contract fulfillment (such as shipping goods to them or providing services).

Consent

Consent is a major concern of the PIPL and a key legal basis on which handlers can process personal information.

If there is no other legal basis for processing data, handlers must get consent for data collection and processing, and this consent can be revoked by any individual at any time.

Handlers are not allowed to refuse to provide products or services if an individual withholds or withdraws their consent for non-essential processing.

Separate consent is also specifically required in a number of situations:

Transfer of personal data by data controllers to third parties (Article 23);

Publication of personal data (Article 25);

Publication or provision of personal data collected by equipment installed in the public places for security purposes, such as personal images (Article 26);

Processing of sensitive personal data (Article 29); and

Cross-border transfers of personal data (Article 39).

Consent for these situations cannot be "bundled" and thus must be obtained separately from the individual.

Where a change occurs in the purpose of personal information handling, the handling method, or the categories of handled personal information, the individual's consent shall be obtained again.

Individual rights

Individuals have several specific rights under the PIPL – they can:

Know & Decide - Refuse and limit how their data is handled.

Access & Copy – View and copy their data.

Correct or Complete – Request to correct inaccurate data.

Erasure – Request their information be deleted and/or revoke consent.

Explanation – Request handlers explain their handling of an individual's personal information.

Portability – Request moving their data to another handler.

Automated decision making

There are specific rules for automated decision making in the PIPL, including the right of individuals to opt-out, such as disabling product recommendations.

The law specifically requires "transparency of the decision-making and the fairness and justice of the handling result shall be guaranteed, and they may not engage in unreasonable differential treatment of individuals in trading conditions such as trade price, etc."

For companies pushing delivery or commercial sales to individuals through automated decision-making methods shall simultaneously provide the option to not target an individual's characteristics, or provide the individual with a convenient method to refuse.

When the use of automated decision-making produces decisions with a major influence on the rights and interests of the individual, they have the right to require personal information handlers to explain the matter, and they have the right to refuse that personal information handlers make decisions solely through automated decision-making methods.

Automated Decision Making is defined as "refers to the activity of using computer programs to automatically analyze or assess personal behaviors, habits, interests, or hobbies, or financial, health, credit, or other status, and make decisions."

Facial recognition

The PIPL specifically covers the use of facial recognition in public spaces, including that it can only be used for public security reasons unless each individual separately consents:

"The installation of image collection or personal identity recognition equipment in public venues shall occur as required to safeguard public security and observe relevant State regulations, and clear indicating signs shall be installed. Collected personal images and personal distinguishing identity characteristic information can only be used for the purpose of safeguarding public security; it may not be used for other purposes, except where individuals' separate consent is obtained."

Handler obligations

Personal information handlers have several specific obligations:

Formulating internal management structures and operating rules;

Implementing categorized management of personal information;

Adopting corresponding technical security measures such as encryption, de-identification, etc.;

Reasonably determining operational limits for personal information handling, and regularly conducting security education and training for employees;

Formulating and organizing the implementation of personal information security incident response plans;

Other measures provided in laws or administrative regulations.

All handlers must "regularly engage in audits of their personal information handling and compliance with laws and administrative regulations."

Personal information protection officers

In addition, at a certain (not yet defined) data handling scale, handlers must appoint "personal information protection officers, to be responsible for supervising personal information handling activities as well as adopted protection measures, etc."

Impact assessment

Under the following circumstances, handlers must perform a personal information protection impact assessment and report the results:

Handling sensitive personal information;

Using personal information to conduct automated decision-making;

Entrusting personal information handling, providing personal information to other personal information handlers, or disclosing personal information;

Providing personal information abroad;

Other personal information handling activities with a major influence on individuals.

Such assessments must include:

Whether or not the personal information handling purpose, handling method, etc., are lawful, legitimate, and necessary;

The influence on individuals' rights and interests, and the security risks;

Whether protective measures undertaken are legal, effective, and suitable to the degree of risk.

Data localization

The PIPL has specific requirements on data localization, the storage and processing of personal information in China.

Data security

Information handlers have several responsibilities, including adopting the following measures to ensure personal information handling conforms to the provisions of laws and administrative regulations, and prevent unauthorized access as well as personal information leaks, distortion, or loss:

Formulating internal management structures and operating rules;

Implementing categorized management of personal information;

Adopting corresponding technical security measures such as encryption, de-identification,

etc.;

Reasonably determining operational limits for personal information handling, and regularly conducting security education and training for employees;

Formulating and organizing the implementation of personal information security incident response plans;

Other measures provided in laws or administrative regulations.

Impact assessments

Impact assessments are required in a number of situations, including:

Handling sensitive personal information;

Using personal information to conduct automated decision-making;

Entrusting personal information handling, providing personal information to other personal information handlers, or disclosing personal information;

Providing personal information abroad;

Other personal information handling activities with a major influence on individuals.

Contractual elements

Agreements are required when a handler entrusts personal data handling to another handler.

Some law firms have suggested this will result in specific standard contractual clauses ("SCC"), similar to in the GDPR.

Breach notification

All data leaks must be reported internally, and if "harm may have been created" they may be required to notify the individuals affected. Notification details must include:

The information categories, causes, and possible harm caused by the leak, distortion, or loss that occurred or might have occurred;

The remedial measures taken by the personal information handler and measures individuals can adopt to mitigate harm;

Contact method of the personal information handler.

Large handlers

Large-scale handlers, such as those "providing important Internet platform services, that have a large number of users, and whose business models are complex" also have the obligations:

Establish and complete personal information protection compliance systems and structures according to State regulations, and establish an independent body composed mainly of outside members to supervise personal information protection circumstances;

Abide by the principles of openness, fairness, and justice; formulate platform rules; and clarify the standards for intra-platform product or service providers' handling of personal information and their personal information protection duties;

Stop providing services to product or service providers on the platform that seriously violate laws or administrative regulations in handling personal information;

Regularly release personal information protection social responsibility reports, and accept society's supervision.

Overseas transfers

Moving personal information outside China is only allowed if one of these conditions is satisfied:

Passing a security assessment organized by the State cybersecurity and information

department according to Article 40 of this Law;

Undergoing personal information protection certification conducted by a specialized body according to provisions by the State cybersecurity and information department;

Concluding a contract with the foreign receiving side in accordance with a standard contract formulated by the State cyberspace and information department, agreeing upon the rights and responsibilities of both sides;

Other conditions provided in laws or administrative regulations or by the State cybersecurity and information department.

All such transfers require each individual's separate consent and notification about "the foreign receiving side's name or personal name, contact method, handling purpose, handling methods, and personal information categories, as well as ways or procedures for individuals to exercise the rights provided in this Law with the foreign receiving side, and other such matters."

In March 2024, the Provisions on Promoting and Regulating Cross-Border Data Flows, which CAC had issued, became effective. These provisions aim to integrate obligations across the Cybersecurity Law, the Data Security Law, and the Personal Information Protection Law. Among other measures, it in certain circumstances it requires a CAC-led review of data exports across China's borders.

Sharing data with foreign governments

Information handlers are prohibited from sharing any personal information with foreign judicial or law enforcement agencies with approval.

This has raised concerns among law firms about how multi-national corporations would or could respond to judicial inquiries in other countries, such as a warrant for data held about a Chinese citizen in those countries.

Government departments

The PIPL includes legal basis for how government ("State Organs") can collect and process data. Generally, the government must follow the same rules as non-government entities, including notifications. There are some exceptions, such as when it "shall impede State organs' fulfillment of their statutory duties and responsibilities".

See also

Cybersecurity Law of the People's Republic of China (CSL)

Cybersecurity

Data Security Law of the People's Republic of China (DSL)

Data governance

Information privacy

General Data Protection Regulation (GDPR)

California Consumer Privacy Act (CCPA)

Children's Online Privacy Protection Act (COPPA)

EU-US Privacy Shield

Human rights

Data portability

Do Not Track legislation

Privacy Impact Assessment

== Citations ==